

CHECKLIST DE GOVERNANÇA NIS2 PARA O ÓRGÃO DE GESTÃO

Art. 20.º Diretiva NIS2 · Arts. 12.º–14.º DL 125/2025 · Revisão: Trimestral

**Como usar:** Marque ☒ cada item cumprido. Preencha os campos amarelos. Esta checklist é evidência de supervisão ativa para o CNCS.  
Frequência recomendada: trimestral. Arquivo: Dossier de Conformidade NIS2 | Ref. interna: GOV-CHK-[Trimestre]-[Ano]

Empresa:

Período:

Data:

■ FORMAÇÃO E COMPETÊNCIA (Art. 20.º §2 NIS2)

A gestão de topo frequentou formação em cibersegurança nos últimos 12 meses

☐ **Evidência:** Certificados de formação arquivados no dossier de conformidade  
☒ Obrigação legal directa — Art. 20.º §2 NIS2. Falta de formação = negligência comprovável

Todos os colaboradores receberam formação/sensibilização em cibersegurança este ano

☐ **Evidência:** Listas de presença assinadas + resultados simulações phishing  
☒ Meta: 100% dos colaboradores. Frequência mínima: anual. Simulações phishing: trimestral

CISO formalmente nomeado com carta assinada pelo CEO e reporte directo à gestão

☐ **Evidência:** Carta de Nomeação arquivada + registo no CNCS actualizado  
☒ Se não existe CISO interno: contratar CISO-as-a-Service ou nomear responsável formal

■ DOCUMENTAÇÃO E POLÍTICAS

Política de Segurança da Informação (PSI) aprovada e assinada pela gestão

☐ **Evidência:** PSI com data de aprovação ≤12 meses e assinatura do CEO  
☒ A PSI é o documento mestre — sem PSI aprovada pela gestão, não há conformidade NIS2

PSI comunicada a todos os colaboradores e confirmação de leitura obtida

☐ **Evidência:** Emails de distribuição + confirmações de leitura ≥90% dos colaboradores

Registo de Riscos de Cibersegurança revisto e actualizado nos últimos 12 meses

☐ **Evidência:** Registo com data de revisão e aprovação da gestão de topo  
☒ O Registo de Riscos é evidência central em qualquer auditoria CNCS

Orçamento de cibersegurança aprovado com linha específica no orçamento anual

☐ **Evidência:** Documento orçamental com rubrica de cibersegurança aprovado pela gestão  
☒ A alocação de recursos é obrigação legal — proporcional ao risco identificado

■ IMPLEMENTAÇÃO TÉCNICA — SUPERVISÃO

☐

**MFA (autenticação multifator) ativo em 100% dos sistemas e contas críticas**

**Evidência:** *Relatório do painel M365/Azure AD mostrando 100% de adoção*

■ *MFA é a medida com maior ROI. Sem MFA: vulnerabilidade crítica face ao CNCS*

☐

**Teste de restauro de backup realizado e documentado nos últimos 3 meses**

**Evidência:** *Relatório de teste com RTO medido e assinado pelo responsável de TI*

■ *Backup sem teste não é backup — é risco não gerido*

☐

**Plano de Resposta a Incidentes (IRP) existente, atualizado e testado**

**Evidência:** *IRP com data ≤12 meses + relatório de exercício tabletop*

■ *O IRP é evidência de preparação — auditores CNCS pedem sempre*

☐

**Patches críticos (CVSS≥9) aplicados em ≤48h nos últimos 6 meses**

**Evidência:** *Relatório de gestão de patches dos últimos 6 meses*

■ SUPERVISÃO E REPORTE À GESTÃO

☐

**Relatório trimestral de cibersegurança recebido e analisado pela gestão**

**Evidência:** *Relatório CISO com data + ata de reunião onde foi apresentado*

■ *A supervisão activa pela gestão é obrigação — não basta receber, tem de analisar*

☐

**KPIs de segurança revistos — % MFA, % patches, taxa phishing, incidentes**

**Evidência:** *Dashboard de KPIs (Excel Aula 1.3) actualizado para o período*

■ *KPIs permitem à gestão supervisionar sem entrar nos detalhes técnicos*

☐

**Fornecedores críticos de TI avaliados com cláusulas NIS2 nos contratos**

**Evidência:** *Lista de fornecedores críticos + contratos com cláusulas actualizadas*

■ *Obrigação do Art. 21.º §3 NIS2 — segurança da cadeia de abastecimento*

■ RESPOSTA A INCIDENTES E REPORTE AO CNCS

☐

**Prazos de notificação ao CNCS conhecidos por toda a equipa de gestão de crise**

**Evidência:** *Cartão de emergência NIS2 afixado + formação sobre os prazos*

■ *24h (aviso) + 72h (notificação) + 1 mês (relatório final) — prazos legais intransponíveis*

☐

**Todos os incidentes (mesmo não reportáveis) registados no log de incidentes**

**Evidência:** *Log de incidentes com todos os eventos do período — mesmo os menores*

■ *Log de incidentes é evidência de monitorização contínua para o CNCS*

☐

**Seguro de ciberrisco avaliado e/ou contratado com cobertura adequada**

**Evidência:** *Apólice de seguro ou avaliação documentada da decisão de não contratar*

■ *Não é obrigatório mas é boa prática de transferência de risco — gestão deve decidir*

DECLARAÇÃO DE REVISÃO

Declaro que a presente checklist foi preenchida de forma completa e honesta, reflectindo o estado real da governança de cibersegurança.

Preenchida por (CISO):

Aprovada por (CEO):

Nome e assinatura:

Data:

Nome e assinatura:

Data: